

Cours 1 : Introduction à la Sécurité des Systèmes d'Information

Odile PAPINI

ESIL

Université de la méditerranée

Odile.Papini@esil.univ-mrs.fr

<http://odile.papini.perso.esil.univmed.fr/sources/SSI.html>

Plan du cours 1

- 1 Introduction
- 2 Etat des lieux
- 3 Les normes ISO 17799, ISO 27002

Plan du cours

- **Introduction**
- **Etat des lieux**
- **Normes ISO 17799, ISO 27002**
- **Panorama des menaces**
- **Panorama des attaques**
- **Politiques de sécurité**
- **Contrôle d'accès**
- **Détection d'intrusions**
- **Biométrie**

Introduction

Système d'information (définition)

Le système d'information comprend les matériels informatiques et les équipements périphériques, les logiciels et microprogrammes, les algorithmes et spécifications internes aux programmes, la documentation, les moyens de transmission, les procédures, les données et les informations qui sont collectées, gardées, traitées, recherchées ou transmises par ces moyens ainsi que les ressources humaines qui les mettent en oeuvre.

Introduction

Sécurité :

- protection contre les accidents
- protection physique
- qualité de l'environnement
- fiabilité des systèmes, pannes, tolérance de pannes
- systèmes de secours, sauvegardes, maintenance
- qualité de base des logiciels
- confidentialité, intégrité, disponibilité
- intrusion réseau
- virus, piratage, ...

Introduction

L'information numérique est vulnérable

- peut être détruite, amputée, falsifiée, modifiée
- pas d'original, ni de copies mais des clones où la reproduction est à l'identique

L'information numérique est volatile

- peut être ajustée, personnalisée
- un document générique peut être particularisé pour un destinataire spécifique
- un logiciel général peut être ajusté selon le contexte ou ciblé selon un usage spécifique

Introduction

sécurité des SSI : concepts clés

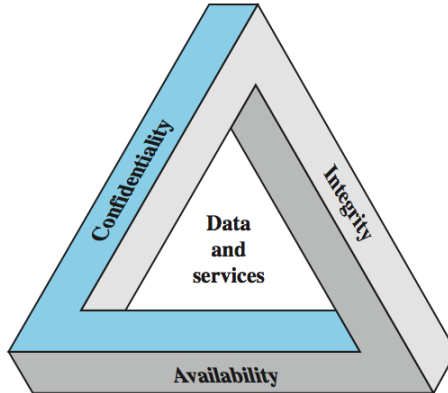


FIG.: source : W. Stallings & L. Brown

Introduction : périmètre de la sécurité des SSI

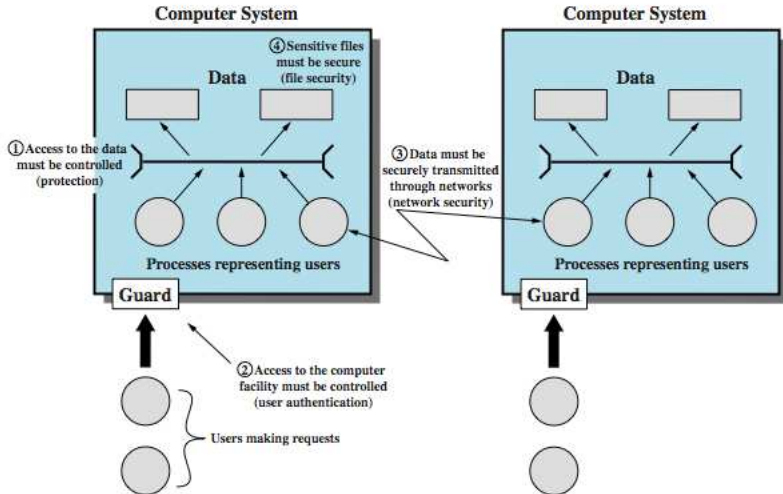


FIG.: source : W. Stallings & L. Brown

Introduction

les enjeux de la sécurité des SSI

- **maîtriser le traitement, le stockage, le transport de l'information**
- **valoriser les contenus**
 - multimédia, logiciel, propriétés intellectuelles, ...
 - libre circulation des contenus
 - disséminer les oeuvres, rétribuer les auteurs
- **asseoir la confiance dans l'univers numérique**
 - e-commerce, e-buisness, e-gouvernement, ...
- **sécuriser**
 - les personnes (libertés, protection de d'intimité)
 - les entreprises et organisations (prévention des risques)

Introduction

Sécurité :

norme ISO 27002 (ex ISO 17799 :2005) : décrit les différents items à couvrir dans le domaine de la sécurité des SSI

Qui est concerné par la sécurité des SSI ?

- les informaticiens
- les dirigeants
- les utilisateurs
- tous les membres du groupe concernés par le système d'information

Introduction

Pluridisciplinarité de la sécurité :

- éthique
- législation
- réglementation
- technique
- méthodologie
- normes

Introduction

vulnérabilité des systèmes d'information

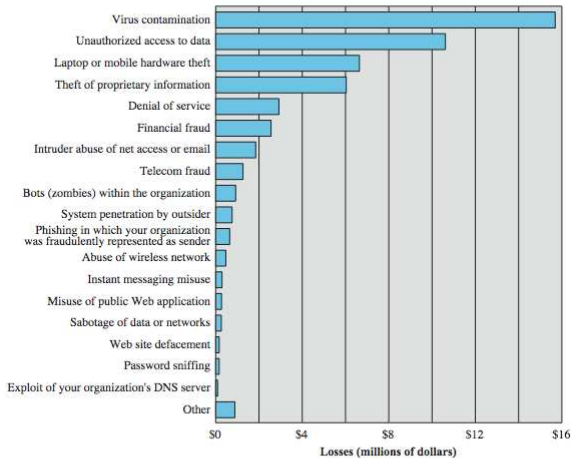
- **cohabitation de nouvelles et anciennes applications**
- **interconnection de différents SI**
- **ouverture du SI vers l'extérieur (internet)**
- **télémaintenance, infogérance**
- **mobilité, nomadisme**

Introduction

origine des sinistres

- **attaques logiques**
- **virus**
- **malveillance**
- **erreurs / négligence**
- **catastrophes naturelles**
- **terrorisme . . .**

Introduction



Source: Computer Security Institute/FBI 2006 Computer Crime and Security Survey

FIG.: au niveau international (source : FBI 2006) (1)

Introduction

conséquences :

- **fermeture de l'entreprise**
- **perte financière**
- **perte de contrat**
- **litige**
- ...

Introduction

Sécurité des SSI

- enjeu économique et social fondamental
 - aussi enjeu pour l'intégrité de la nation
 - défi permanent
-
- les risques sont énormes
 - mais(heureusement) il y a peu de sinistres (déclarés)
 - cependant il faudrait anticiper : la sécurité a un coût

Introduction

Mise en place d'une politique de sécurité (PSI)

- liens sensibles
- menaces
- impacts
- mesures à adopter

55% des entreprises sont dotées d'une PSI (source : rapport CLUSIF 2008)

Etat des lieux : les entreprises

définir une politique de sécurité :

- aspects techniques
- aspects humains

communiquer, sensibiliser :

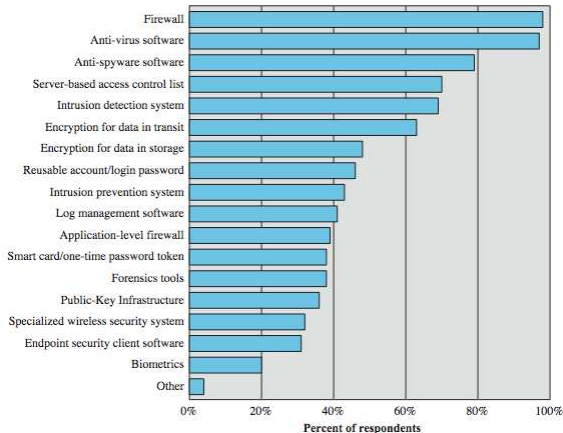
- aspects techniques
- aspects humains

Introduction

Mise en oeuvre d'une politique de sécurité :

- système d'authentification (biométrie, serveur d'authentification , ...)
- chiffrement (PKI, mécanismes intégrés à des protocoles de communication (IPsec), ...)
- pare feux (firewall)
- système anti-virus
- outil de détection de failles de sécurité
- système de détection d'intrusions
- système d'exploitation sécurisé
- ...

Introduction



Source: Computer Security Institute/FBI 2006 Computer Crime and Security Survey

FIG.: au niveau international (source : FBI 2006) (2)

Etat des lieux

**La sécurité en quelques chiffres :
sources CLUSIF, 2008
[http ://www.clusif.asso.fr/](http://www.clusif.asso.fr/)**

enquête réalisée auprès de :

- 354 entreprises de plus de 200 salariés
- 194 collectivités locales, conseils, régionaux, généraux, mairies de plus de 30 00 habitants
- 1139 internautes

Etat des lieux : Méthodologie de l'enquête

norme ISO 27002(ex 17799) pour les entreprises et collectivités :

- thème 5 : politique de sécurité
- thème 6 : organisation de la sécurité et moyens
- thème 7 : gestion des risques liés à la sécurité des SI
- thème 8 : sécurité des ressources humaines (charte, sensibilisation)
- thème 10 : gestion des communications et des opérations
- thème 11 : contrôle des accès
- thème 12 : acquisition, développement et maintenance
- thème 13 : gestion des incidents de sécurité
- thème 14 : gestion de continuité
- thème 15 : conformité (CNIL, audits, tableaux de bord)

thème 9 : sécurité physique non abordé

Etat des lieux : méthodologie de l'enquête

thèmes abordés pour les internautes

- caractérisation socioprofessionnelle et identification des outils informatiques
- usage de l'informatique et d'internet à domicile
- gestion des risques liés à la sécurité des SI
- perception de la menace informatique, sensibilité aux risques et à la sécurité, incidents rencontrés
- pratiques de sécurité mises en oeuvre (comportement, solutions techniques)

Etat des lieux : les entreprises

secteurs d'activités

- BTP
- Commerce
- Industrie
- Services, banque, assurances
- Transport
- Télécoms

Etat des lieux : les entreprises

effectifs de l'échantillon

n : effectifs	pourcentage
$200 \leq n \leq 499$	66%
$500 \leq n \leq 999$	19%
$n > 1000$	15%

Etat des lieux : les entreprises

rapport CLUSIF 2008 :

[http ://www.clusif.asso.fr/fr/infos/event/#conf080619](http://www.clusif.asso.fr/fr/infos/event/#conf080619)

Etat des lieux : les collectivités locales

collectivités locales

- Mairies de plus de 30 000 habitants
- Communautés d'agglomération de plus de 50 000 habitants
- Communautés de communes de plus de 20 000 habitants
- Conseils généraux
- Conseils régionaux

Etat des lieux : les collectivités locales

échantillon

collectivités	pourcentage
mairies	34%
communautés de communes	32%
communautés d'agglomération	20%
conseils généraux	11%
conseils régionaux	3%

Etat des lieux : les collectivités locales

rapport CLUSIF 2008 :

[http ://www.clusif.asso.fr/fr/infos/event/#conf080619](http://www.clusif.asso.fr/fr/infos/event/#conf080619)

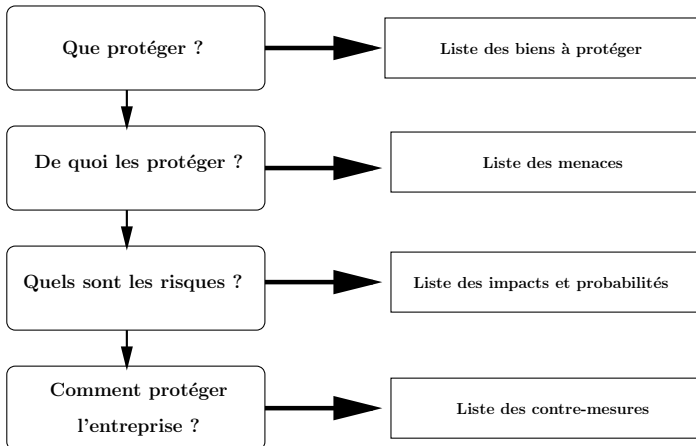
Etat des lieux : les internautes

rapport CLUSIF 2008 :

[http ://www.clusif.asso.fr/fr/infos/event/#conf080619](http://www.clusif.asso.fr/fr/infos/event/#conf080619)

Les normes ISO 17799, ISO 27002

Sécurité



Les normes ISO 17799, ISO 27002

Normes internationales concernant la sécurité de l'information les plus récentes

- norme ISO 17799 : différentes versions
- norme ISO 17799 : 2005 de juin 2005 à juin 2007
- norme ISO 27002 depuis juillet 2007

Titre de la norme ISO 27002 :

Code de bonnes pratiques pour la gestion de la sécurité l'information

http://www.iso.org/iso/iso_catalogue/catalogue_tc/catalogue_detail.htm?csnumber=39612

La norme Norme ISO 17799

- objectifs et recommandations pour la sécurité informatique
- publiée en juin 2005
- répondre aux préoccupations globales de sécurisation des entités pour l'ensemble de leurs activités

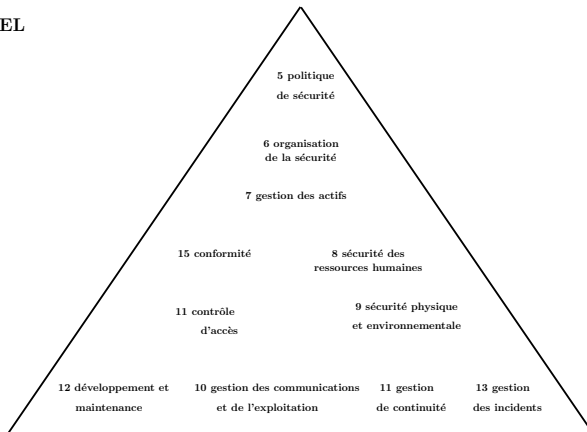
La norme Norme ISO 17799

ARCHITECTURE DE LA NORME ISO 17799

ORGANISATIONNEL



OPERATIONNEL



La norme Norme ISO 17799

couverture thématique de la norme ISO 17799

la norme identifie des objectifs pour la sécurité informatique selon 3 critères :

- **confidentialité** : absence de divulgation non autorisée d'informations
- **intégrité** : prévention de modifications ou de suppressions non autorisée d'informations
- **disponibilité** : garantit l'accès aux informations du système

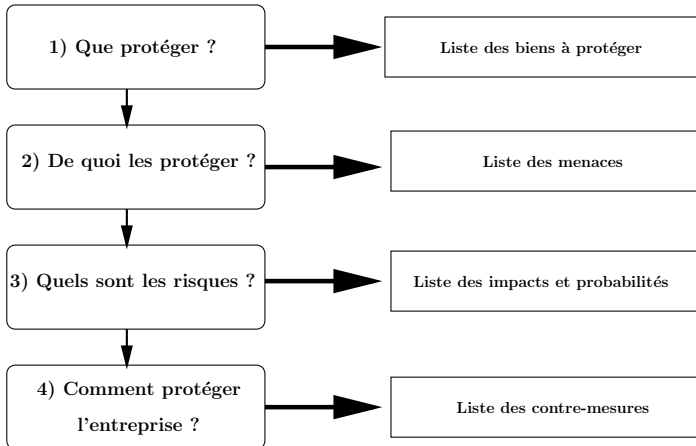
La norme Norme ISO 17799

les objectifs de sécurité sont regroupés en 11 thématiques :

- **politique de sécurité**
- **organisation de la sécurité**
- **classification et contrôle du "patrimoine informationnel"**
- **sécurité et ressources humaines**
- **sécurité physique**
- **gestion des opérations et des communications**
- **contrôle d'accès**
- **acquisition, développement, maintenance**
- **gestion des incidents**
- **gestion de la continuité d'activité**
- **conformité à la réglementation interne et externe**

La norme Norme ISO 17799

Sécurité



La norme Norme ISO 17799

mise oeuvre de la norme ISO 17799

étapes 1) - 3) : laissées aux entités (choix de méthodologie)

étapes 4) : corps de la norme ISO 17799

Il est nécessaire de :

- d'identifier les exigences légales et réglementaires
- d'identifier les enjeux de l'entité et les attentes qui en découlent
- de définir un périmètre de mise en application de la norme

La norme Norme ISO 17799

analyse de risques

la norme ISO 17799 recense des modalités et des règles pour traiter les risques (réduire, transférer, prendre ou refuser les risques)

la norme ISO 17799 recommande en complément une analyse de risques, (sans préciser la méthode)

les méthodes reconnues les plus connues (en France) :

- MARION (CLUSIF) : <https://www.clusif.asso.fr/>
- MEHARI (CLUSIF) :
<https://www.clusif.asso.fr/fr/production/mehari>
- EBIOS (DCSSI) :
<http://www.ssi.gouv.fr/fr/confiance/ebios.html>

La norme Norme ISO 17799

norme ISO 17799 : outil de communication

référentiel pour communiquer :

- à l'intérieur de l'entité (responsables, personnels)
- à l'extérieur de l'entité (partenaires, clients)

La norme Norme ISO 17799

De	A	sur quoi communiquer
responsable sécurité	direction générale	besoin d'établir une politique de sécurité inspirée de l'ISO 17799
	toute l'entité	la sensibilisation des services et des personnels
	toute l'entité	le bien-fondé des mesures de sécurité à mettre en place
	direction générale	la conformité des mesures de sécurité par rapport au cadre de la norme
entité	clients	la cohérence de la démarche de sécurité avec la norme ISO 17799
	partenaires	le bien-fondé d'imposer des exigences de sécurité cohérentes avec ISO 17799

La Norme ISO 17799

la norme ISO 17799 n'est pas une certification

certification :

- délivrée par un organisme indépendant
- permet d'attester la conformité d'un produit, système, service
- s'appuie sur un audit

Les normes ISO 17799, ISO 27002

Norme ISO 27002 en vigueur depuis juillet 2007

Titre de la norme ISO 27002 : **Code de bonnes pratiques pour la gestion de la sécurité l'information**

évolution de la norme ISO 17799 :2005 pallie ses principales insuffisances :

- définition de niveaux de sécurité,
- la méthodologie d'analyse et de gestion des risques (norme ISO 27005),
- la notion de plan d'action,
- la notion d'indicateurs et de métriques de sécurité (norme ISO 27004).

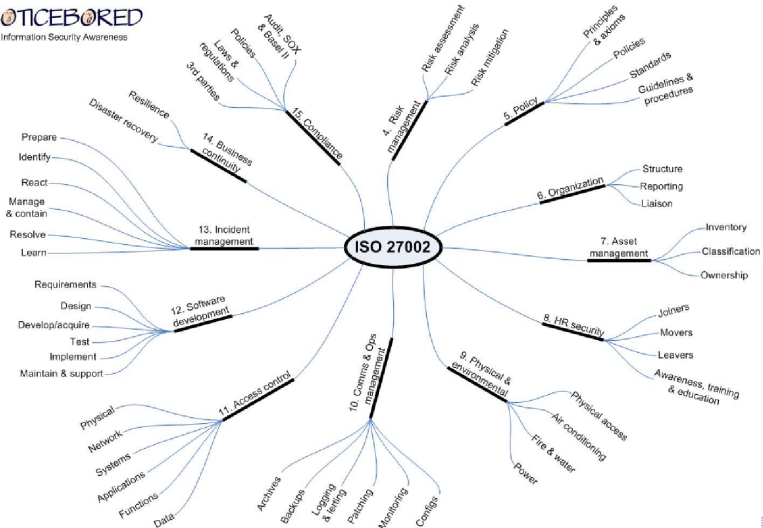
http://www.iso.org/iso/iso_catalogue/catalogue_ics/catalogue_detail_ics.htm?csnumber=50297

Les normes ISO 17799, ISO 27002

organisées sur 12 thèmes :

- **Chapitre 4 : Appréciation et traitement du risque.**
- Chapitre 5 : Politique de sécurité.
- Chapitre 6 : Organisation de la sécurité de l'information.
- Chapitre 7 : Gestion des biens.
- Chapitre 8 : Sécurité liée aux ressources humaines.
- Chapitre 9 : Sécurité physique et environnementale.
- Chapitre 10 : Gestion des communications et de l'exploitation.
- Chapitre 11 : Contrôle d'accès.
- Chapitre 12 : Acquisition, développement et maintenance des systèmes d'information.
- Chapitre 13 : Gestion des incidents liés à la sécurité de l'information.
- Chapitre 14 : Gestion de la continuité d'activité.
- Chapitre 15 : Conformité légale et réglementaire.

Les normes ISO 17799, ISO 27002



Les normes ISO 17799, ISO 27002

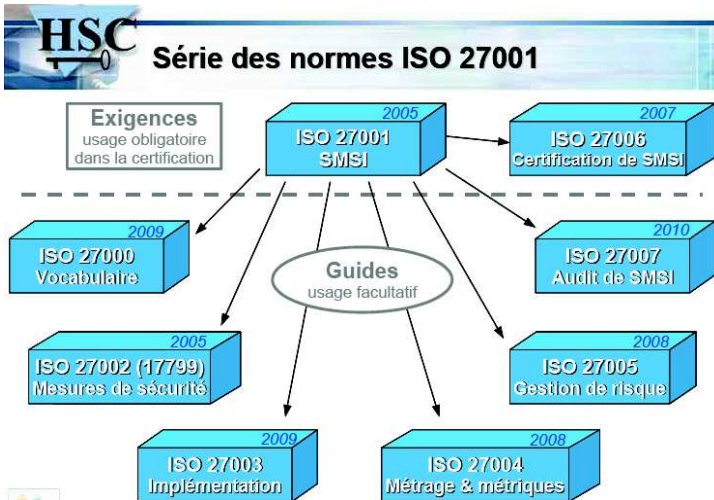


FIG.: (source : Hervé Schauer consultants)

Les normes ISO 17799, ISO 27002



- Mesurage du Management de la Sécurité de l'Information
 - *Security control* → mesure de sécurité donc pour éviter les confusions :
Measurement → mesurage
 - Guide de mise en place du mesurage du SMSI
 - Etat : CD, publication prévue en 2008, déjà utilisable et très utile
 - Objectif : mesurer l'efficacité du SMSI et des mesures de sécurité
 - Programme de mesurage et processus de mesurage
 - Rôles et responsabilités
 - Méthodologie de choix des indicateurs
 - Production et exploitation des indicateurs
 - Analyse et restitution des indicateurs
 - Amélioration du processus de mesurage



Exemples d'indicateurs

FIG.: (source : Hervé Schauer consultants)

Les normes ISO 17799, ISO 27002

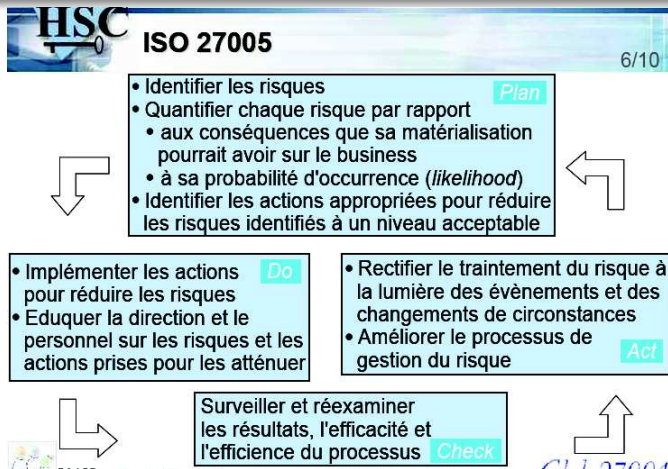


FIG.: (source : Hervé Schauer consultants)

Les normes ISO 17799, ISO 27002

Références pour les normes ISO 27004 et ISO 27005 :

[http ://www.hsc.fr/ressources/presentations/cfssi-iso27-intro/index.html.fr](http://www.hsc.fr/ressources/presentations/cfssi-iso27-intro/index.html.fr)